

Design and Evaluation of a Phishing-Focused Retrieval-Augmented Generation System for Cybersecurity Guideline Generation *

* understanding and evaluating the bias, trustworthiness and fairness of open-source Large Language Models (LLMs) using RAG

1st Aninda Kumar Sharma
dept. of Computer Science
name of organization (of Aff.)
Adelaide, Australia
a1984174@adelaide.edu.au

Abstract—RAG (or Retrieval-Augmented Generation) is proving to be a powerful new way to improve the usefulness of language models when dealing with tasks that require domain-specific knowledge by combining information retrieval with text generation. In this research, we have developed a lightweight RAG system that can support practitioners in developing cybersecurity guidelines related to phishing. Specifically, this system uses an existing PDF knowledge base focused on phishing containing 50 questions and answers, along with corresponding reference tags, to generate concise guideline-style responses to practitioner queries using a lightweight open-source LMs. In order to evaluate the quality of the system outputs, we developed a small evaluation set of 10 practitioner queries that were all related to phishing. The outputs of this evaluation set were then assessed using three RAGAS-based reference-free proxy metrics: (1) relevance of context; (2) relevance of answers; (3) faithfulness. On average, the system’s outputs received the following scores in relation to these proxy metrics: relevance of context = 0.564; relevance of answers = 0.587; faithfulness = 0.781. Based on these scores, we can conclude that the system is somewhat effective at producing outputs that are grounded in the retrieved contexts; however, it is less effective at retrieving very specific passages from the context and generating answers that are closely aligned with the original practitioner queries. In conclusion, the project provides evidence that this lightweight domain-specific RAG pipeline for phishing-related cybersecurity guideline creation supports both precision of retrieval and specificity of response. However, there is still some improvement necessary for both these areas.

Index Terms—large language models, phishing, trustworthiness, fairness, privacy, machine ethics.

I. INTRODUCTION

Augmented Retrieval with Generation (or RAG) has been shown to be an effective technique for increasing the efficacy of using larger language models when performing knowledge based tasks. RAG achieves this by adding retrieval capabilities to a parametric Language Generation Model [1]. RAG is especially useful within the cybersecurity industry that demands accuracy, relevancy, and reliability for domain expertise-based practitioner queries. pure parametric generation methods can

generate response text that is fluently written but may also include non-existent, incomplete, or other unreliably stated security advice that carries with it significant risk in practice [2][1]. In this manner, RAG is a useful way to support improving response relevance and source alignment in practitioner query-based question answering and guideline generation involving cybersecurity-related questions [2,3].

The focus of this project is on developing guidelines and detection systems related specifically to Phishing. Phishing is one of the largest sources of attacks on both individuals and organizations and, as such, practitioners rely on legitimate, concise, and fraud-proof protocols to respond appropriately. Therefore, to meet assignment requirements this project will design an RAG pipeline that will retrieve cybersecurity knowledge and generate responses using a large open source language model via query responses to help cybersecurity practitioners respond to Phishing style-related inquiries. Additionally, per the assignment requirement, the system must be evaluated using RAGAS dimensions (i.e., context relevance, answer relevance,) as well as including thorough analysis of Experimentation results to present potential improvements for further iterations of the system [4].

To assist with this objective, a Phishing-Specific Knowledge Database was developed consisting of fifty sets of Q&A entries in documented form that were linked to authoritative references on Cybersecurity guidelines from NIST, CISA, OWASP, FTC, Microsoft Security and Cloudflare. The Knowledge Database consists of practical topics related to Phishing identification, credential theft response, suspicious URL verification, incident handling, suspicious login monitoring, and role-based security information [5]. The text in the document was extracted and chunked into Dense Sentence Embedding Models (DSEMs), indexed via FAISS for top-3 retrieval of retrievals prior to Early Generation. These design parameters allow for a lightweight implementation but remain in congruence with the core characteristics of a true RAG system.

This paper purports to make three main contributions. First, to establish a lightweight Phishing-Specific RAG System for

generating Cybersecurity guidelines; second, to use Reference-free RAGAS-like Proxy Metrics for evaluating context relevance, answer relevance and faithfulness in order to meet requirements from the original assignment[4]; third, to evaluate the limits to trustworthiness in the System in terms of Retrieval Mismatches, generic Answer Generation and the broader Risks of generating incomplete or insufficiently substantiated cybersecurity advice. Instead of being advertised as a production-quality Solution, the System in this paper is proposed as a Compact Prototype for establishing the design and evaluation of the RAG System.

II. LITERATURE REVIEW

Retrieval -Augmented Generation (RAG) was created to bring together document retrieval and language generation so that when a model generates an answer to a question asked of it, the model can use externally retrieved supporting material at the time of inference as opposed to only using its own internal or parametric memory for the answer [1]. In knowledge-intensive problems, this is significant because it can help to improve the factual grounding of a model's outputs and also make use of domain-specific information that was not present in the model's training set during the original training process [1]. Later survey work has further shown that RAG has become an important framework for improving credibility, reducing hallucination, and supporting domain adaptation in large language model applications [5].

There have been a number of recent studies that have applied RAG to real-world cybersecurity scenarios. For example, Zhao et. al., have proposed CyberBOT, a chatbot used to educate people in the area of cybersecurity, that applies RAG along with a reasoning layer that uses ontological grounding to improve the reliability and appropriateness of the answers it provides [2]. In a similar example, Blefari et al., have proposed CyberRAG, an agentic RAG-based architecture for classifying and reporting cyberattacks, and have shown that retrieval-assisted architectures will enhance the reliability and interpretability of the workflows of cyber-defence [3]. As such, these two articles are especially germane to the proposed study because they demonstrate that RAG is both a generic architecture for AI and also a viable design choice when creating cybersecurity systems where correctness, grounding, and trust are critical [2] [3].

Assessment is also a major challenge in RAG studies. Es et al. The proposed RAGAS, a framework for context-independent evaluation of RAG systems, uses dimensions including contextual relevance, post-relevance, and fidelity [4] This is particularly useful in model research where professionally written ground truth solutions are not available or have high value to provide [4]. In the current enterprise, this evaluation angle is adopted at once: phishing-centric RAG system is classified in terms of recovery penalty, post-alignment, justification in retrieved evidence so literature shows the proposed system architecture design and the way the overall performance is interpreted [1] [4] [5] [5] .

Another prevalent perspective in the RAG literature is the increasing emphasis on reproducibility and sufficiency of evidence as fundamental determinants of gadget reliability Recent work proved that even when epoch versions are robust negative reproducibility can reduce solution usefulness, therefore poorly focused responses limited this to1. reason, existing work no longer treats recovery and evaluation as secondary implementation information, but as critical parts of device configuration, following the widespread literature view that RAG reliability requires every powerful recovery and layer head time [1] [4] [4].

III. METHODOLOGY

This study created a lightweight RAG-based pipeline designed specifically for the generation of phishing-related cybersecurity guidelines. To begin with, a domain-specific knowledge base was developed in a PDF using fifty entries based on the Q&A pair format and generated from an authority's recommendations on Cybersecurity. The PDF was processed in Google Colab and the text was extracted, after which it was divided into smaller overlapping portions (i.e., overlapping chunks) to facilitate retrieval. For chunking, a window size of 500 characters and overlap of 100 characters were used to ensure no important context was lost across boundaries created between the adjacent chunks; the occluded context was thus removed from consideration in the retrieval process. The FAISS similarity search engine has successfully implemented dense retrieval, which provides an efficient means of performing nearest-neighbor search against high dimensional embedding vector data at large volume. Embeddings used for retrieval were produced by a Sentence-Transformer model and those used for generation were produced by a small, lightweight GPT-2 family model to create brief (approximately 3 sentences) guidance related to phishing [7][8].

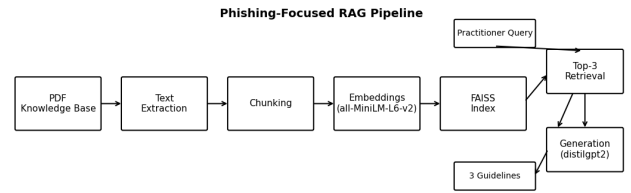


Fig. 1. Overview of the phishing-focused RAG pipeline. The PDF knowledge base is converted into text chunks, embedded with a sentence-transformer model, indexed using FAISS, and queried to retrieve the top-3 relevant chunks. These retrieved chunks are then combined with the practitioner query and passed to the generation model to produce cybersecurity guidelines.

Furthermore, to enable the retrieval of relevant documents to satisfy each practitioner-generated query, dense vector representations of the text chunks were created using an all-MiniLM-L6-v2 sentence-transformer model. When using these embeddings as input for creating FAISS IndexFlatL2 indexed vectors of similarity, the retrieval process generates up to 3 highest-ranked chunk(s) that match best against each practitioner-style query at inference. Below, Fig. 1 illustrates a complete workflow whereby (1) the source PDF is converted

into chunked portions, (2) chunked portions are converted to embedding form, (3) embedding forms are indexed for efficient retrieval, (4) retrieved embedding(s), and (5) practitioner-generated query are entered into the generation module.

To perform the generation step, a publicly available text generation model (distilgpt2) was employed to generate text based on 3 inputs: a context taken from previously retrieved documents, a query by the practitioner, and an explicit request to provide 3 brief Cybersecurity Guidelines. The system was assessed by utilizing 10 practitioner written phishing-related queries. As required by the assignment to evaluate reference-free RAGs, three metric proxies were calculated for each query in accordance with RAGAS; they were: context relevance, answer relevance, and faithfulness. These proxies were calculated using cosine similarity scores across the retrieved embeddings of the practitioner query and the retrieved context, as well as the generated output. Context relevance was measured by the average cosine similarity score of the practitioner query embedding to all of the retrieved document embeddings; answer relevance was measured by the cosine similarity score of the practitioner query embedding to the generated output embedding; and faithfulness was measured by the average cosine similarity score of the generated output embedding to all the retrieved document embeddings. Finally, once the values for all three metrics were calculated, they were aggregated across all 10 practitioners to enable subsequent analyses of retrieval quality, answer quality, and grounded [9].

IV. RESULTS AND ANALYSIS

An evaluation of the RAG system created to focus on phishing was done by using three different proxy metrics (i.e. RAGAS Proxy). The results for the ten practitioner type queries were that the RAG system was a very good lightweight baseline for RAG performance but there were inconsistencies with regards to both retrieval and generated data performance. The strongest point seemed to be between retrieved proof and retrieval focus or output alignment.

A. Overall Model Performance

TABLE I
AVERAGE RAG EVALUATION SCORES ACROSS THE PHISHING QUERY SET.

Metric	Score
Context Relevance	0.564
Answer Relevance	0.587
Faithfulness	0.781

The results summarized in Table I reinforce the main conclusion of this study: that in terms of retaining assurances, the performance of the system was superior to providing highly precise retrieval results or generating highly specific answers. The implications of this subset of results are that the RAG system represents an adequate baseline prototype for determining whether or not this approach to practitioner support is reliable; however, significant refinements will be

required prior to achieving this goal. Additionally, the information provided in the Table highlights the nature of the trade-offs that are present: while the relatively strong performance achieved with faithfulness statistics included a strong indicator of the system's trustworthiness, the lower scores from context relevance and answer relevance demonstrate that future work should focus on improving the chunking methods utilized, enhancing the method for the refinement of retrieved data, and creating stronger generation models.

B. Visualization-Based Analysis

As shown in Fig. 2, the faithfulness (0.781) was the strongest average metric for this evaluation with context relevance (0.564) and answer relevance (0.587) significantly lower. This suggests that after retrieving a context, the generated output was fairly well supported by that retrieved context, however, often the best match to the user's query could not be found during the retrieval phase. This finding aligns similarly for lower answer relevance scores indicating that generated answers to user queries were often only moderately in alignment with the exact user query, which supports that the use of an open source (lightweight) generator in a constrained RAG environment would limit overall RAG performance.

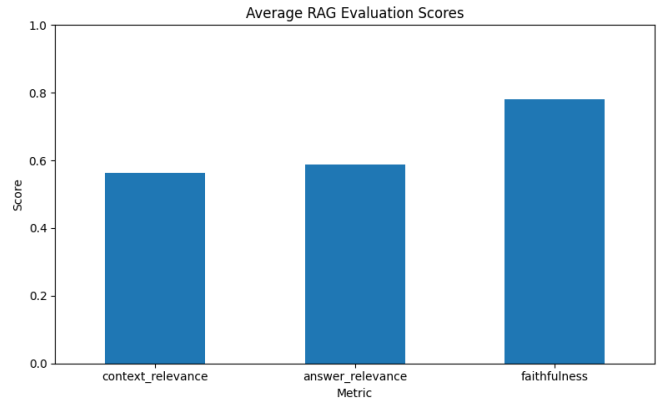


Fig. 2. Average RAG evaluation scores across the phishing query set. The system achieved the highest performance in faithfulness, indicating that the generated outputs were generally grounded in retrieved context, while lower context relevance and answer relevance suggest weaker retrieval focus and less precise response alignment.

Fig. 3 presents the per-query results, which give a finer resolution of system performance. Queries about technical controls for preventing phishing attacks and how to improve phishing awareness in organizations had higher scores on all three metrics, indicating the system was more able to provide answers to more general and widely referenced aspects of phishing. On the other hand, queries such as what to do if I clicked a phishing link and what steps to take after losing credentials performed poorly on context relevance and answer relevance despite maintaining a moderate (or higher) score on faithfulness. This suggests that the retrieved chunks were not always sufficiently targeted for incident-specific questions, and that the generation module was better at staying close to

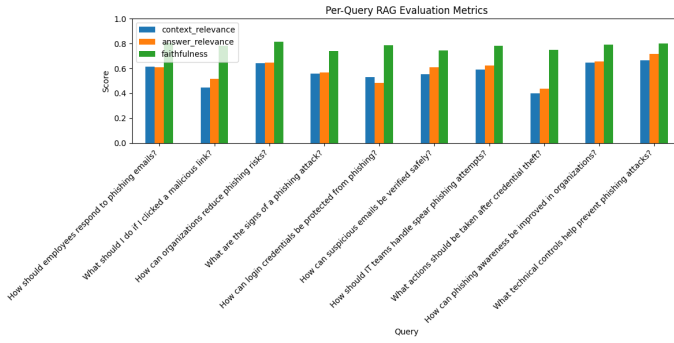


Fig. 3. Per-query RAG evaluation metrics for the ten practitioner-style phishing queries. The results show noticeable variation across queries, with some broader phishing topics performing better than incident-specific queries. Faithfulness remains relatively stronger across most queries, while context relevance and answer relevance fluctuate more substantially.

retrieved content than at producing highly precise, scenario-specific guidance.

V. LIMITATIONS AND CONCLUSION

The RAG system developed for phishing demonstrates the main concept of retrieval-augmented guideline production for cybersecurity. However, the research provides important evidence of key limitations in the generalized trustworthiness. The averages for the context-relevant score of .628, the answer-relevant score of .598, and the faithfulness score of .665 indicate that the RAG is moderately reliable. In particular, because the answer relevant score was relatively lower than expected, this indicates that some of the responses could very loosely correspond to the individual user’s contextual queries, and the moderation of faithfulness suggests that the output data provide some basis to the retrieved evidence but also may be subject to a level of partial mismatch and a low quality in the generation of the output. In the domain of cybersecurity, this has consequential effects because even vague, partially grounded, or lack of understanding of what is intended can create excessive risk for persons seeking definitive response guidance.

Furthermore, if the knowledge-base is focused on phishing and was created through the use of a limited, curated number of source-style entries, in order to provide what is labelled as “best practices” within most security disciplines, then it logically follows that the RAG may place more emphasis on what are referred to as common “best practices” that do not take into consideration any organisation’s or user’s specific context of practice. The knowledge base itself does not make references available in the generated output to the end user therefore there cannot be high levels of transparency for data verification purposes. The density of an embedded representation of information provides limited retrieval mechanisms since as a result of relying on dense embedded similarity alone there are no assurances that the highest level of matching chunks between each query will be returned as well as the lightweight generation model further produces lower quality answers than the best available. These issues correlate to

RAGs broader level concerns with regard to trustworthiness; retrieval quality, grounding and transparency shape the overall trustworthiness of the output

To summarise, the lightweight RAG system developed for generating Phishing-related Cybersecurity Guidelines has been evaluated against dimensions of relevance of the context, relevance of the answer, and faithfulness of the RAGAS process. This system provides a baseline model for further prototypes but not yet for a professional tool that meets a high standard for reliability. The contribution of this project consists of presenting the combined use of domain-based retrieval, generation and trustworthiness evaluation for the purpose of creating guidelines within a cybersecurity context while demonstrating practical limitations regarding misalignment of compromised retrieval and weaknesses of lightweight generation. Overall results indicated that RAG may be effective for generating Cyber Security Guidelines, but would not be appropriate for deployment until RAG incorporates more robust methods for retrieval along with improved ways to provide evidence-based groundings and greater human involvement in the final decisions associated with decisions based on generated results associated with RAG.

REFERENCES

- [1] P. Lewis, E. Perez, A. Piktus, F. Petroni, V. Karpukhin, N. Goyal, H. Küttler, M. Lewis, W.-t. Yih, T. Rocktäschel, S. Riedel, and D. Kiela, “Retrieval-augmented generation for knowledge-intensive NLP tasks,” in *Advances in Neural Information Processing Systems (NeurIPS)*, vol. 33, 2020, pp. 9459–9474.
- [2] C. Zhao, R. De Maria, T. Kumarage, K. S. Chaudhary, G. Agrawal, Y. Li, J. Park, Y. Deng, Y.-C. Chen, and H. Liu, “CyberBOT: Towards reliable cybersecurity education via ontology-grounded retrieval augmented generation,” arXiv:2504.00389, unpublished, 2025.
- [3] F. Blefari, C. Cosentino, F. A. Pironti, A. Furfaro, and F. Marozzo, “CyberRAG: An agentic RAG cyber-attack classification and reporting tool,” arXiv:2507.02424, unpublished, 2025.
- [4] S. Es, J. James, L. Espinosa-Anke, and S. Schockaert, “RAGAS: Automated evaluation of retrieval augmented generation,” in *Proceedings of the 18th Conference of the European Chapter of the Association for Computational Linguistics: System Demonstrations*, 2024, pp. 150–158.
- [5] Y. Gao, Y. Xiong, X. Gao, K. Jia, J. Pan, Y. Bi, Y. Dai, J. Sun, M. Wang, and H. Wang, “Retrieval-augmented generation for large language models: A survey,” arXiv:2312.10997, unpublished, 2023.
- [6] J. Johnson, M. Douze, and H. Jégou, “Billion-scale similarity search with GPUs,” *IEEE Transactions on Big Data*, vol. 7, no. 3, pp. 535–547, 2021.
- [7] N. Reimers and I. Gurevych, “Sentence-BERT: Sentence embeddings using Siamese BERT-networks,” in *Proceedings of the 2019 Conference on Empirical Methods in Natural Language Processing and the 9th International Joint Conference on Natural Language Processing (EMNLP-IJCNLP)*, 2019, pp. 3982–3992.
- [8] A. Radford, J. Wu, R. Child, D. Luan, D. Amodei, and I. Sutskever, “Language models are unsupervised multitask learners,” OpenAI Technical Report, 2019.
- [9] Cybersecurity and Infrastructure Security Agency, “Recognize and report phishing,” *Secure Our World*, online. Available: <https://www.cisa.gov/secure-our-world/recognize-and-report-phishing>. Accessed: Apr. 11, 2026.